

AWS Security Best Practices

- ◇ Implement a robust password policy with strong, unique passwords and regular rotation.
- ◇ Enable multi-factor authentication (MFA) for all IAM users
- ◇ Use a centralized identity provider for simplified management and authentication processes
- ◇ Regularly audit IAM user credentials and access keys
- ◇ Rotate IAM user access keys at regular intervals and prioritize the use of IAM roles
- ◇ Leverage IAM roles to delegate access permissions and reduce the risk of exposure
- ◇ Utilize IAM policies to precisely control user actions and adhere to the principle of least privilege
- ◇ Regularly review IAM roles, policies, and access patterns, and remove unnecessary permissions while rotating credentials regularly.
- ◇ Organize users into IAM groups based on their roles for simplified permission management
- ◇ Use managed policies over custom policies to reduce errors and simplify policy management.
- ◇ Never expose AWS access keys and credentials in source code; manage them as secrets in CI/CD pipeline or vault and use them as environment variables.
- ◇ Implement policy conditions to restrict access based on additional criteria for added security.
- ◇ Thoroughly test policies and roles in a development or staging environment before deployment to production.
- ◇ Utilize VPCs to isolate AWS resources into virtual network environments with full control over network traffic and resource access.
- ◇ Control inbound and outbound network traffic using security groups as virtual firewalls for AWS resources within a VPC.
- ◇ Implement the principle of least privilege in security groups.
- ◇ Open only the necessary ports and protocols required for the resource to function.
- ◇ Restrict outbound traffic to necessary destinations to ensure resource functionality.
- ◇ Utilize separate security groups for different resource types
- ◇ Use security groups in conjunction with network ACLs for network security
- ◇ Implement separate network ACLs for public and private subnets
- ◇ Regularly review and update security group rules and network ACLs
- ◇ Employ AWS services like AWS WAF to protect web applications from common exploits
- ◇ Use NAT Gateway to provide secure internet access for resources in private subnets

- ◇ Leverage AWS Shield for managed DDoS protection
- ◇ Utilize AWS Firewall Manager to centrally manage security components across multiple accounts
- ◇ Implement Amazon GuardDuty for continuous monitoring of AWS accounts
- ◇ Use AWS Trusted Advisor to identify security vulnerabilities in your AWS infrastructure
- ◇ Employ AWS CloudTrail to record all activities within your AWS account
- ◇ Configure CloudTrail to log specific events and store the logs in designated S3 buckets
- ◇ Monitor CloudTrail logs using Amazon CloudWatch and set up alerts for specific events
- ◇ Use AWS CloudWatch for monitoring and setting alarms for security-related thresholds.
- ◇ Utilize AWS Amazon Inspector for security assessments using pre-configured templates.
- ◇ Keep software updates and security patches up to date using tools like Amazon Inspector and AWS Systems Manager.
- ◇ Secure data in Amazon S3 buckets using server-side encryption with options like SSE-S3, SSE-KMS, or SSE-C.
- ◇ Encrypt Elastic Block Store (EBS) volumes to protect data on EC2 instances using KMS keys.
- ◇ Use SSL/TLS to protect transmitted data, especially crucial for data moving between applications and AWS services.
- ◇ Utilize encryption in transit for AWS services such as API Gateway and AWS Direct Connect
- ◇ Use a centralized service for backing up data across AWS services
- ◇ Schedule and automate regular backups for services like Amazon EBS, RDS, DynamoDB, and others
- ◇ Test backups and recovery procedures for data integrity and availability
- ◇ Implement a Pilot Light setup for a minimal version of the environment for quick scaling in a disaster
- ◇ Set up a Warm Standby as a scaled-down but functional version of the full environment that is always running
- ◇ Consider a Multi-Site setup with two full environments in parallel, one active and one on standby
- ◇ Implement dashboards for continuous monitoring of AWS resource health
- ◇ Use alarms for proactively managing and responding to performance issues
- ◇ Create a trail that records all events and delivers log files to an Amazon S3 bucket for analysis and archival.
- ◇ Have a well-defined incident response plan

- ◇ Conduct regular reviews and audits of your AWS environment to ensure alignment with best practices and compliance requirements.
- ◇ Perform vulnerability assessments using tools like Amazon Inspector.
- ◇ Integrate AWS logs with Security Information and Event Management (SIEM) tools for comprehensive analysis.
- ◇ Track changes in your AWS environment to provide a detailed inventory of AWS resources
- ◇ Ensure to review, examine, and assess the settings of your AWS resources.
- ◇ Utilise AWS Config rules to define desired configurations and evaluate compliance changes.
- ◇ Continuously monitor and record your AWS resource configurations to assist with internal and external compliance audits.
- ◇ Securely delete data that is no longer required using deletion policies.

Disclaimer: The provided article is intended for educational and knowledge-sharing purposes related to cybersecurity only; its primary goal is to educate and promote cybersecurity awareness among the cybersecurity communities.